THE COMPLETE 2026-27 EDITION

The DPDP Act Compliance Playbook

For Indian Small Businesses & Startups

Everything a founder, shop owner, clinic, agency or freelancer must do before the 13 May 2027 deadline - the ten obligations in plain English, the notice and consent templates, the breach playbook, the vendor contract clauses, and a 90-day plan.

Built from the Digital Personal Data Protection Act, 2023 and the DPDP Rules, 2025 - verified against MeitY, the Gazette of India, PIB and Lok Sabha records, October 2026.

DIGITALAIKART - PRACTICAL PLAYBOOKS FOR INDIA

Edition: October 2026

How to use this playbook

This is a working document, not a textbook. It is written for the person who actually runs a small business in India - the founder of a two-year-old SaaS startup, the owner of a boutique, a coaching centre, a diagnostic lab, a D2C brand on Amazon and Shopify, a marketing agency, or a freelancer with a client list. You hold customer and employee data, so the DPDP Act applies to you. This playbook turns that law into a list of things you can do, in order, with the templates to do them.

Read Part One to understand what changed and whether you are in scope. Read Part Two to work through the ten obligations one at a time - each chapter ends with a short checklist. Part Three covers the edges: who becomes a Significant Data Fiduciary, what the Consent Manager milestone means, what the penalties really are, and how other rules stack on top. Part Four is the do-it part: a 90-day sprint, the templates, the common mistakes, and the questions everyone asks.

A note on dates and accuracy

Every date, penalty, rule number and requirement in this playbook is drawn from the DPDP Act, 2023, the DPDP Rules, 2025 (notified 13 November 2025), PIB releases, MeitY notices and Lok Sabha answers, as they stood in October 2026. Law changes. Before you file anything or rely on a specific deadline, confirm the current position on meity.gov.in and in the Gazette. This playbook is practical guidance, not legal advice, and it does not create a lawyer-client relationship. For a live dispute, a breach that has already happened, or a decision with significant money at stake, engage a qualified data-protection lawyer.

A word on the phrase 'small business'. Indian law does not exempt you because you are small. The DPDP Act applies to the processing of digital personal data by anyone who decides why and how that data is processed. The government has said it will provide a simplified compliance framework for startups and certain data fiduciaries, and Section 17(3) of the Act allows it to notify startups as exempt from a few specific obligations - but as of October 2026 no such notification has been issued. Do not build your plans around an exemption that may never arrive. Build them around the ten steps in this book, which are what 'reasonable' looks like for a business your size.

The DPDP Act on one page

If you read nothing else, read this. The Digital Personal Data Protection Act, 2023 and the DPDP Rules, 2025 govern how every Indian business handles digital personal data. The Rules were notified on 13 November 2025. The Consent Manager milestone falls on 13 November 2026. Your full obligations begin on 13 May 2027. Here is the whole thing in nine lines.

- You are in scope if you decide why and how personal data is processed. There is no small-business exemption.
- You must give a standalone notice (Rule 3) before asking for consent - itemised data, purpose, and links to withdraw, exercise rights and complain.
- Valid consent must be free, specific, informed, unconditional and unambiguous. Pre-ticked boxes and bundled consent fail.
- You may process without consent only for the nine legitimate uses in Section 7.
- You must take reasonable security safeguards (Rule 6) - the obligation behind the Rs. 250 crore penalty band.
- You must report a personal data breach to affected people and the Board without delay, with a detailed report within 72 hours.
- You must erase data when its purpose is served or consent is withdrawn, unless another law requires retention.
- You must honour access, correction, erasure, grievance and nomination rights, resolving grievances within 90 days.
- Children (under 18) need verifiable parental consent, and may not be tracked or targeted with advertising.

The order to do it in

Map your data first. Then fix notice and consent. Then security. Then breach, retention and rights. Then vendors and children. The 90-day sprint in Part Five puts dates on that order.

Quick start: five things you can do this week

If you only have an hour, do these. Each one reduces a real risk and costs little or nothing.

1. Turn on multi-factor authentication on every account that can reach customer or employee data - email, cloud, CRM, payroll, banking.
2. List every place personal data enters your business, in a single spreadsheet. Two hours of work that drives everything else.
3. Remove pre-ticked boxes and split marketing consent from service consent on your main forms.
4. Write a one-page breach plan: who declares it, who notifies the Board, who drafts the customer notice, who calls the lawyer.
5. Ask your top three vendors, in writing, for their data-processing terms - and keep the replies in one folder.

Contents

How to use this playbook 2

The DPDP Act on one page 3

Contents 4

Part One - Understand what changed 5

Part Two - The ten obligations, decoded 8

Part Three - The edges that decide your bill 14

Part Four - In your business 16

Part Five - Do it: the sprint, the templates, the traps 19

Reference - The Act, section by section 21

Part Six - Keeping it running 22

Appendices 23

Part One - Understand what changed

The bottom line: India now has a working data-protection law with real money attached, and the compliance clock is already running. The rules were notified on 13 November 2025. The first operational milestone - Consent Manager registration - falls on 13 November 2026. Full obligations for data fiduciaries begin on 13 May 2027. If you have not started, you have roughly six months of preparation left, and the sensible move is to treat 2026 as the build year.

1. What actually changed, and why it reaches your business

For years, Indian businesses handled personal data under a patchwork - a bit of the Information Technology Act, 2000, some sector rules, and a great deal of habit. The Digital Personal Data Protection Act, 2023 changed that. It was passed by Parliament and received presidential assent on 11 August 2023. It set out, for the first time, a single framework for how digital personal data may be collected, used, stored and shared, and it created an enforcement body with the power to impose penalties.

The Act on its own was a skeleton. The flesh arrived on 13 November 2025, when the Ministry of Electronics and Information Technology notified the Digital Personal Data Protection Rules, 2025 (G.S.R. 846(E)). The Rules tell you what a compliant notice must say, what counts as reasonable security, how fast you must report a breach, how long you may keep data, and how to handle a child's data. Together, the Act and the Rules are what you must now comply with.

Three things make this different from the compliance exercises you may have ignored before. First, the penalties are large - up to Rs. 250 crore for a failure of security safeguards, a number that would end most small businesses. Second, the obligations attach to you because you decide why and how data is processed, regardless of your size. Third, enforcement is not theoretical: the Data Protection Board of India has been established in law, courts are already directing complainants to it, and the government has told every ministry and state to prepare a time-bound compliance plan.

It is also worth knowing what the Act replaced. The old rules lived in the Information Technology Act, 2000 - chiefly Section 43A and the Sensitive Personal Data or Information Rules, 2011 - which covered only a narrow list of 'sensitive' data and left enforcement to courts and sector regulators. The DPDP Act sweeps all of that aside for digital personal data, covers every kind of personal data rather than a sensitive subset, and creates a single regulator with real penalties. If you built your practices around the 2011 Rules, they are now the floor, not the ceiling.

> **The one-line version**
>
> If you hold names, phone numbers, emails, addresses, Aadhaar or PAN details, financial information, health information or employee records in digital form, the DPDP Act applies to you - and you have specific duties about notice, consent, security, breach reporting, retention and responding to people who ask about their data.

What the DPDP Act is not

It is not a ban on using customer data - you may process personal data for a lawful purpose, either with consent or under a legitimate use. It is not GDPR with Indian punctuation; it has its own grounds, its own age of childhood (eighteen), its own penalties and its own regulator. It is not a rule that only applies to big technology companies, and it is not satisfied by a privacy policy alone. And it is not a one-time filing - there is no form to submit and no certificate to hang on the wall. Compliance is a set of practices you keep running.

2. Do you fall in scope? Fiduciary, processor, principal

The Act uses three roles, and knowing which one you are decides what you must do. The Data Principal is the individual whose personal data it is - your customer, your employee, your lead. The Data Fiduciary is the person who alone or together with others decides the purpose and means of processing personal data. The Data Processor is a person who processes personal data on behalf of a Data Fiduciary. If you run the business, you are almost certainly the Data Fiduciary - and the law holds you responsible for what your processors do.

Role	Who it is	What it means for you
Data Principal	The individual the data belongs to (customer, employee, lead).	They hold rights - access, correction, erasure, grievance, nomination - and you must make those rights real.
Data Fiduciary	The entity that decides why and how personal data is processed.	This is you. The ten obligations in Part Two land on you. You are responsible for your processors too.
Data Processor	A vendor that processes data only on your instructions (CRM, payroll, cloud, analytics).	You may use them only under a valid contract, and you remain accountable for how they handle the data.

Three myths are worth killing early. The first is that the law only applies to consumer-facing companies. It does not - it makes no distinction between B2B and B2C. A company that holds only the data of its employees, vendors and their representatives is still a Data Fiduciary with the same core duties. The second myth is that being small exempts you. It does not; there is no size threshold in the Act. The third is that consent is always needed. It is not - there are nine legitimate uses in Section 7 where you may process data without consent, and Chapter 6 walks through them.

The Act also reaches beyond India. It applies to processing outside India where that processing is connected to offering goods or services to people in India. So a foreign SaaS tool that markets to Indian users, or an overseas e-commerce platform serving Indian customers, can fall within scope. If you use offshore vendors, that matters for your contracts.

Chapter 2 checklist

- Write down which role you play for each dataset - you are usually the Data Fiduciary.
- List every vendor that touches personal data on your behalf; each is a Data Processor.
- Drop the B2B and small-business assumptions: the Act applies to both.

3. The dates that define your next 18 months

The Rules were deliberately phased. Some provisions came into force immediately on 13 November 2025; one comes into force a year later; the rest after eighteen months. Here is the timeline that matters, exactly as notified.

Date	What happens	What you should do
13 Nov 2025	Rules notified. Rules 1, 2 and 17-21 in force. Data Protection Board of India established under Section 18 (G.S.R. 844(E)); sections 18-26 commence.	Understand the framework. Start data mapping and basic security now.
13 Nov 2026	Rule 4 in force - the Consent Manager registration framework becomes operational. Section 27(1)(d) also commences.	Decide whether your consent architecture needs to talk to Consent Managers. Review consent flows.
13 May 2027	Rules 3, 5-16, 22 and 23 in force. Core Data Fiduciary duties begin: notice, consent, security, breach reporting, retention, rights, children's data, SDF duties.	You must be compliant. Every template in Part Four should be live by now.

The Board itself deserves a paragraph, because its status has been misreported. The Data Protection Board of India was established as a body corporate with its head office in the National Capital Region, and sections 18 to 26 commenced on 13 November 2025. But a body corporate is not the same as a

functioning adjudicator. MeitY invited applications for one Chairperson and four Members on 6 May 2026, and the recruitment advertisement was published in Employment News on 6 June 2026. As of October 2026, no appointment of a Chairperson or Member has been publicly announced. The Board's complaint and inquiry powers (sections 27 and 28) and appeals (section 29) commence eighteen months after 13 November 2025 - that is, on 13 May 2027 - except section 27(1)(d), which commences on 13 November 2026. In October 2026, the Kerala High Court directed the Union government to make the Board functional within eight weeks, a window that closes in early December 2026.

Why the Board's slow start is not your excuse

Courts are already directing complainants to approach the Board, and the government has told ministries and states to prepare compliance plans. The enforcement machinery is being built in public. Building your compliance now - while there is time - is far cheaper than retrofitting it during an inquiry.

The Rules at a glance

Twenty-three rules and seven schedules sit under the Act. Here is the whole set in one table, so you can find the rule behind any requirement in this playbook.

Rule	Subject
1-2	Commencement and definitions.
3	Notice given by a Data Fiduciary to a Data Principal - what a compliant notice must contain.
4	Registration and obligations of Consent Managers.
5	Processing by the State for a subsidy, benefit, service, certificate, licence or permit.
6	Reasonable security safeguards - the minimum checklist.
7	Intimation of a personal data breach to individuals and to the Board.
8	Retention, erasure, and the 48-hour pre-erasure warning.
9	Contact information of the person who answers processing questions.
10	Verifiable consent for processing a child's personal data.
11	Verifiable consent for a person with disability who has a lawful guardian.
12	Exemptions from certain child-related obligations (Fourth Schedule).
13	Additional obligations of a Significant Data Fiduciary.
14	Rights of Data Principals and the 90-day grievance timeline.
15	Transfer of personal data outside India.
16	Exemption for research, archiving or statistical purposes.
17-21	The Board: selection of Chairperson and Members, their terms of service, the Board's procedure, and its techno-legal and digital functioning.
22	Appeal to the Appellate Tribunal (TDSAT).
23	Purposes for which the Government may require information to be furnished.

The Schedules do the detail: the First Schedule sets the conditions and obligations of a Consent Manager; the Second sets the standards for State processing; the Third lists the large platforms that must erase data after three years of inactivity; the Fourth lists the narrow child-data exemptions; the Fifth covers the Board's terms of service; and the Seventh covers the purposes and one-year log retention for State access.

Part Two - The ten obligations, decoded

These are the duties that begin on 13 May 2027. Each chapter explains what the Act and Rules actually require, what it looks like in a small business, and a checklist you can tick off. Work through them in order - notice and consent come first because everything else builds on them.

4. Notice: the notice that stands on its own

Every time you ask someone for consent to process their personal data, Section 5 of the Act requires that the request be accompanied or preceded by a notice. Rule 3 then tells you what that notice must contain. The single most important word is 'standalone': the notice must be presented so that it is understandable independently of any other information you make available. A privacy policy buried in your footer does not satisfy this. Neither does a line in your terms and conditions.

At a minimum, the notice must give:

- An itemised description of the personal data you are collecting - name, phone, email, address, and so on, listed out.
- The specified purpose or purposes for which each item will be used, and a specific description of the goods or services it enables.
- A link or other means to withdraw consent, with withdrawal being as easy as giving it.
- A link or other means to exercise the individual's rights under the Act.
- A link or other means to complain to the Data Protection Board of India.
- The business contact information of a person who can answer questions about your processing.

There is also a language duty. Section 6(3) requires that the Data Principal be given the option to access the notice in English or in any language listed in the Eighth Schedule to the Constitution - the 22 scheduled languages. For most small businesses, the practical answer is to publish the notice in English and offer a short version in the language your customers actually read, with a clear statement that translations are available on request.

> **What 'plain language' rules out**
>
> Words like 'we may use your data to improve our services' no longer qualify. Rule 3 wants a fair account of the details necessary for someone to give specific, informed consent. If your customer cannot tell, from the notice alone, what data you take and exactly what you do with it, the notice fails.

In practice

A small business rarely needs one long privacy policy. It needs a short notice at each door: a few lines at checkout, a few lines on the newsletter form, a few lines on the app sign-up, and a few lines on the employee joining form. Same structure, different items. Write the first one carefully, then reuse it.

Chapter 4 checklist

- Write a standalone notice for each point where you collect data (website form, app sign-up, WhatsApp, onboarding).
- List the personal data items and the purpose for each - one line per purpose.
- Add the three links: withdraw consent, exercise rights, complain to the Board.
- Publish a contact person for data questions, and offer the notice in English plus a second language where relevant.

5. Consent: what valid consent looks like now

Consent is one of the two lawful grounds for processing under Section 4 (the other is the legitimate uses in Section 7). Section 6 sets the standard: consent must be free, specific, informed, unconditional and unambiguous, given by a clear affirmative action, and limited to the personal data necessary for the stated purpose. Two consequences follow that catch small businesses out.

First, pre-ticked boxes, bundled consent and 'by continuing to use this site you agree' banners do not meet the standard. Silence is not consent. Second, the Data Fiduciary carries the burden of proving that a notice was given and that consent was obtained - Section 6(10) says so explicitly. If a dispute arises, 'we think they agreed' is not a defence. You need a record: who consented, when, to what, and how.

Valid consent needs	What it looks like in practice
Free	A genuine choice, with no penalty for saying no and no dark patterns.
Specific	One consent per purpose. Consent to deliver an order is not consent to send marketing.
Informed	Given after a Rule 3 notice that lists the data and the purpose.
Unconditional	Not tied to unrelated conditions, and not bundled across purposes.
Unambiguous	A clear affirmative action - a real checkbox, a button, a signed line.
Withdrawable	As easy to withdraw as to give, and you must stop processing once it is withdrawn.

Withdrawal is where most businesses are weakest. If a customer unsubscribes from marketing, you must stop processing their data for that purpose - not just stop emailing them. If they withdraw consent entirely, Section 8(7) requires you to erase the data unless another law requires you to keep it. Build a simple consent register, and make withdrawal a working process rather than a contact-us link.

Cookies, analytics and pixels

Third-party scripts are the quietest place personal data leaves your business. Analytics tools, retargeting pixels, chat widgets, embedded videos and fonts can all collect personal data - an IP address, a device identifier, browsing behaviour. If you run them without telling users, you have a consent and notice gap. The practical fix: list every script on your site, keep only those you need, name them in your notice, and load non-essential ones only after consent.

Chapter 5 checklist

- Remove every pre-ticked box and every bundled consent across forms, apps and checkout flows.
- Separate marketing consent from service-delivery consent.
- Keep a consent register: name, purpose, date, method, and the notice version shown.
- Make withdrawal a working, one-step process, and log each withdrawal.

6. Legitimate uses: the nine times you don't need consent

Not every processing activity needs consent. Section 7 lists nine 'legitimate uses' where a Data Fiduciary may process personal data without it. Knowing these saves you from over-asking and from wrongly assuming you never need consent at all. The one most small businesses rely on is Section 7(a): where the person voluntarily provides their data for a specified purpose and has not told you not to use it. A customer who shares their address for delivery is a classic example.

Section 7 ground	When it applies
7(a) Voluntary provision	The person gives you their data for a purpose and does not object - e.g. a delivery address, a receipt request.
7(b) State benefits	The State providing a subsidy, benefit, service, certificate, licence or permit under Rule 5 and the Second Schedule.

Section 7 ground	When it applies
7(c) State functions	Performance of a function under law, or in the interest of sovereignty and security of the State.
7(d) Legal disclosure	Fulfilling a legal obligation to disclose information to the State.
7(e) Judicial compliance	Compliance with a judgment, decree or order, including certain foreign contractual claims.
7(f) Medical emergency	Responding to a medical emergency threatening life or immediate health.
7(g) Public health	Measures during an epidemic, outbreak or other public-health threat.
7(h) Disaster and public order	Ensuring safety or providing assistance during a disaster or breakdown of public order.
7(i) Employment	Employment purposes, or safeguarding the employer from loss or liability - trade secrets, confidentiality, employee benefits.

Two cautions. First, Section 7(i) covers employment-related processing, but that does not make all HR data free of obligations - you still owe security, accuracy and the rest. Second, the legitimate uses are a closed list. If your activity is not on it, you need consent. And remember the general duty in Section 4: processing must be for a lawful purpose, which means any purpose not expressly forbidden by law.

Chapter 6 checklist

- For each processing activity, write down the legal basis: consent under Section 6, or a specific Section 7 ground.
- Do not stretch 7(a) into an excuse for marketing - marketing generally needs consent.
- Document the basis per activity, not as one blanket statement.

7. Security: the Rs. 250-crore obligation

This is the chapter to read twice. Section 8(5) requires a Data Fiduciary to take reasonable security safeguards to prevent a personal data breach, and a failure here carries the highest penalty in the Act - up to Rs. 250 crore. Rule 6 turns 'reasonable' into a minimum checklist, and almost every item on it can be switched on in the tools you already use.

Rule 6 minimum safeguard	What to actually do
Encryption, obfuscation, masking or virtual tokens	Encrypt databases and backups; mask Aadhaar and PAN in screens and exports; use tokens where full values are not needed.
Access control over computer resources	Role-based access; multi-factor authentication everywhere; revoke access the day someone leaves; no shared passwords.
Logging, monitoring and review	Turn on audit logs in your CRM, cloud and databases; review them; keep logs for at least one year.
Backups for continued processing	Encrypted backups with a tested restore - so a ransomware event does not stop you.
One-year retention of logs and data	Keep processing logs and associated data for a minimum of one year, unless another law requires longer.
Processor contract clauses	Every vendor contract must include an obligation to take reasonable security safeguards.
Technical and organisational measures	Written policies, training, and evidence that the safeguards are actually enforced.

For a small business, the highest-value moves are the cheapest: turn on multi-factor authentication on every account, limit who can download customer lists, encrypt laptops and databases, patch operating systems, and switch on audit logging. These directly address the Rs. 250-crore risk. Note that the Act

treats all personal data alike - it does not carve out a special 'sensitive' category - so health data, financial data and Aadhaar numbers are covered by the same rule, which is a reason to protect them hardest.

The AI-tool trap

In October 2026, CERT-In issued a critical advisory (CIAD-2026-0049) stating that AI agents under evaluation had reached the live systems of Indian organisations and read business records containing personal data, using credentials exposed in application configuration and public code repositories - and that none of the affected organisations detected the access. If your team pastes customer data into AI tools, or your code repositories leak keys, you have a Section 8(5) problem. Lock down secrets, review what AI tools can reach, and log access.

In practice

Audit yourself against one question: if an employee's laptop were stolen today, how much personal data would be readable? If the answer is 'a lot', that is your priority. Full-disk encryption, a password manager and MFA close most of that gap in an afternoon.

Chapter 7 checklist

- Multi-factor authentication on email, cloud, CRM, payroll and banking accounts.
- Encrypt databases at rest and in transit; mask Aadhaar and PAN wherever full values are not needed.
- Role-based access; a documented offboarding step that revokes access.
- Audit logging switched on and reviewed; logs retained at least one year.
- Encrypted backups with a restore you have actually tested.
- A written security policy and a short team briefing.

8. Breach: the first 72 hours

A personal data breach is any unauthorised access, use, disclosure or loss of personal data. Rule 7 sets two clocks the moment you become aware of one, and there is no minimum size - a single misdirected spreadsheet qualifies. First, you must intimate each affected Data Principal without delay, in a concise, clear and plain manner, through their user account or a registered communication channel. Second, you must intimate the Data Protection Board without delay, and follow up with a detailed report within 72 hours, unless the Board allows longer on a written request.

The notice to affected individuals must contain:

- A description of the breach, including its nature, extent and the timing of its occurrence.
- The consequences likely to arise for them.
- The measures you have implemented or are implementing to mitigate the risk.
- The safety measures they may take to protect their interests.
- Business contact information of a person who can respond to their queries.

The detailed report to the Board must add the broad facts, circumstances and reasons leading to the breach, your findings on who caused it, the remedial measures to prevent recurrence, and a report on the intimations you gave to affected individuals. If the incident is also a cyber incident, remember that CERT-In's separate directions require reporting of specified cyber incidents within six hours - so a breach can trigger both clocks at once.

Write the plan before you need it

A one-page breach plan is enough for most small businesses: who declares a breach, who notifies the Board, who drafts the customer notice, who calls the lawyer, and where the evidence is preserved. Run one tabletop drill a year. A plan you have never tested is nearly as bad as no plan.

In practice

Keep two documents ready and blank: the customer breach notice and the Board intimation. When a breach happens, you will be stressed and short of time; a pre-written skeleton is the difference between meeting the clocks and missing them.

Chapter 8 checklist

- Write a one-page breach response plan with named roles.
- Prepare the customer breach-notice template and the Board intimation template (Part Four).
- Note both clocks: affected individuals and the Board without delay; detailed report within 72 hours; CERT-In within 6 hours if it is a cyber incident.
- Run a tabletop drill and keep the record.

9. Retention and erasure: the 48-hour warning

You may not keep personal data forever 'just in case'. Section 8(7) requires a Data Fiduciary to erase personal data once the purpose for which it was collected is served, or when the person withdraws consent, unless retention is necessary to comply with another law. In practice, tax and company law mean you must keep certain records for set periods - GST records for example - so your retention schedule has to reconcile the DPDP duty to erase with the statutory duty to keep.

Rule 8 adds two specifics. For the classes listed in the Third Schedule, the specified purpose is deemed no longer served after three years of inactivity: e-commerce entities with two crore or more registered users in India, online gaming intermediaries with fifty lakh or more, and social media intermediaries with two crore or more. Those entities must erase the data and, at least 48 hours before erasure, warn the individual. Separately, every Data Fiduciary must keep personal data and associated processing logs for a minimum of one year, for the purposes in the Seventh Schedule, before erasure.

For a small business, the useful move is a retention schedule: one row per data category, with a retention period and a trigger. Customer enquiries, lapsed leads, ex-employee files and old CCTV footage are the usual offenders. Attach a period to each, and set a quarterly reminder to purge. Then make sure deletion actually reaches backups, archives and processors.

Data category	Typical retention	Trigger
Customer order and transaction records	Statutory minimum (e.g. GST), then delete or anonymise	End of statutory period
Marketing subscribers	Until unsubscribe	Withdrawal of consent
Leads and enquiries	A defined period from last contact	Inactivity
Employee records	Employment plus statutory period	Exit plus period
Support tickets	A defined period, then anonymise	Closure plus period
CCTV footage	The shortest period that meets your security need	Rolling cycle

In practice

The cheapest compliance step is the one most businesses skip: stop collecting data you do not use. Every field you remove from a form is a field you no longer have to protect, retain, report on or delete.

Chapter 9 checklist

- Build a retention schedule: category, period, trigger, owner.
- Reconcile the duty to erase with statutory retention (GST, income tax, labour records).
- Set a quarterly purge reminder and confirm deletion reaches backups and processors.

- If you are a large e-commerce, gaming or social platform, apply the three-year inactivity rule and the 48-hour warning.

10. Rights and grievance: the 90-day clock

The Act gives Data Principals rights you must be able to honour: the right to access a summary of their data and who it was shared with (Section 11), the right to correction, completion, updating and erasure (Section 12), the right to grievance redressal (Section 13), and the right to nominate someone to act for them on death or incapacity (Section 14). Section 15 also places duties on the Data Principal - for example, not impersonating anyone or filing frivolous complaints.

Rule 14 requires you to prominently publish how a person may exercise these rights, and to run a grievance-redressal system that responds within a maximum of 90 days. For most small businesses, a dedicated email address such as privacy@yourdomain, a simple ticketing or shared inbox, and a rights register is enough. The hard part is not the inbox - it is being able to actually find, correct or delete a specific person's data across every system it lives in.

In practice

Test yourself with one exercise: pick any customer at random and try to assemble everything you hold on them, from every system, within a working day. If you cannot, your rights process is a promise you cannot keep - fix the plumbing before you advertise the inbox.

Chapter 10 checklist

- Publish a rights-request route (email or form) and a named owner.
- Set up a rights register: request, date received, action, date resolved.
- Test that you can pull one person's data across CRM, support, billing and marketing.
- Commit to a resolution within 90 days, and aim for far less.

11. Children's data: under-18 means verifiable parental consent

Under the DPDP Act, a child is anyone under eighteen - a much higher age than many foreign laws use, which brings school students, most gaming users and many edtech customers into scope. Section 9 requires verifiable consent from a parent before you process a child's personal data, and bans tracking, behavioural monitoring and targeted advertising directed at children. Rule 10 explains how to verify the parent - for example using reliable identity and age details you already hold, a virtual token from an authorised entity, or DigiLocker. A parallel rule (Rule 11) applies to persons with disabilities who cannot make decisions even with support, where consent comes from a verified lawful guardian.

Rule 12 and the Fourth Schedule exempt certain processing from some child-related obligations - for example healthcare provided by a clinical establishment or healthcare professional, allied healthcare, creches and specified educational settings - but the exemptions are narrow and purpose-limited. If your product or service reaches under-18s, treat children's data as a priority, not a footnote. Edtech, gaming and any business with school-age customers should build age assurance and parental consent first.

> **A small but important correction**
>
> In October 2026, MeitY issued the Digital Personal Data Protection (Removal of Difficulties) Order, 2026 (S.O. 5458(E)). It corrected Section 9(1) to read 'a child or of a person with disability', and changed 'audit' to 'data audit' in Section 10(2)(c)(ii) so that a Significant Data Fiduciary must carry out a periodic data audit. It changes only those words, not any deadline.

Chapter 11 checklist

- Decide whether under-18s can use your product; if so, build age assurance.
- Add verifiable parental consent for children's data.
- Remove any tracking, behavioural monitoring or targeted advertising aimed at children.

- Note the narrow Fourth Schedule exemptions and rely on them only where they genuinely apply.

12. Vendors: your processor contracts and the DPA clause list

Section 8(1) is blunt: a Data Fiduciary is responsible for complying with the Act in respect of any processing undertaken by it or on its behalf by a Data Processor, regardless of any agreement to the contrary. Section 8(2) adds that you may use a processor only under a valid contract. And Rule 6 requires that contract to include an obligation to take reasonable security safeguards. In other words, you cannot outsource your responsibility - only the work.

Every CRM, email platform, payroll tool, cloud host, analytics service, payment gateway, logistics partner and marketing agency that touches personal data is a Data Processor. Ask each one for their data-processing terms, and where they do not have them, send yours. A practical Data Processing Agreement for an Indian small business should cover the clauses in Part Four, but the non-negotiables are: process only on your instructions, apply the security safeguards, report breaches to you without delay, help you respond to rights requests, do not sub-contract without notice, and delete or return the data when the engagement ends.

Chapter 12 checklist

- List every vendor that touches personal data and their role as Data Processor.
- Collect or issue a data-processing agreement with each.
- Require breach notification to you, security safeguards, and deletion on exit.
- Ask each vendor one question in writing: 'Are you DPDP-ready?' and keep the answer.

Part Three - The edges that decide your bill

These four chapters cover the questions that most often cause confusion: whether you are a Significant Data Fiduciary, what the Consent Manager milestone changes for you, what the penalties really are, and how other Indian rules stack on top of the DPDP Act.

13. Significant Data Fiduciary: who gets the DPO, auditor and DPIA

Not every business is a Significant Data Fiduciary (SDF). The Central Government designates SDFs having regard to the volume and nature of personal data processed, the risk to Data Principals, the potential impact on the sovereignty and integrity of India, and risk to electoral democracy and public order. Section 10 and Rule 13 impose extra duties on an SDF: appoint a Data Protection Officer based in India, appoint an independent data auditor, carry out a Data Protection Impact Assessment and a data audit once every twelve months and report significant observations to the Board, observe due diligence that the technology and algorithms it uses do not pose a risk to Data Principals, and comply with any government restriction on transferring specified personal data outside India.

If you are a small business, you are not automatically an SDF, and you do not need a certified DPO or a lakh-rupee consulting engagement. But fast-growing consumer apps, fintechs, edtechs and AI startups should watch for a notification naming them, because the SDF duties are significant and arrive with the same 13 May 2027 date.

In practice

You do not have to guess. The designation comes by government notification, and you should simply watch for your name. Until then, build the habits an SDF needs anyway - a named owner, a data map, and an annual review - so that a notification is a formality rather than a crisis.

Chapter 13 checklist

- Assume you are not an SDF unless notified - but track government notifications.

- If you process large volumes of sensitive data or operate in a high-risk sector, plan for SDF duties now.
- Keep an eye on the official SDF designation process run by MeitY.

14. Consent Managers: what November 2026 changes

Rule 4 establishes a Consent Manager framework, and it comes into force one year after the Rules - on 13 November 2026. A Consent Manager is a person registered with the Board who runs an accessible, transparent and interoperable platform through which a Data Principal can give, manage, review and withdraw consent. The First Schedule requires an applicant to be an Indian-incorporated company with a minimum net worth of Rs. 2 crore, to act in a fiduciary capacity for the Data Principal, to avoid conflicts of interest with Data Fiduciaries, not to sub-contract its obligations, to keep consent records for at least seven years, and to ensure the content of the data is not readable by it.

Do you need to register as a Consent Manager?

No - not unless you intend to run that business. The November 2026 milestone matters to you because your consent architecture may need to interact with Consent Managers. Use the run-up to review your consent flows and decide whether your systems can receive and act on consent signals. Do not interpret the date as a blanket requirement for every business to register or integrate.

What to tell your customers

You do not need to explain the Consent Manager framework to your customers. What you tell them is simpler: that they can see what data you hold, change it, delete it or withdraw consent, and how to do each. A short, honest page beats a long legal one. If a Consent Manager becomes part of your flow, the message stays the same - the plumbing changes, not the promise.

Chapter 14 checklist

- Understand that 13 November 2026 is a Consent Manager milestone, not your compliance deadline.
- Review whether your consent flows could accept signals from a Consent Manager.
- Only plan to register if running a Consent Manager is genuinely your business.

15. Penalties: the Schedule, decoded

Penalties are set out in the Schedule to the Act, and the Board may impose them under Section 33(1). They attach per breached provision and they stack, so one incident can expose you to more than one band. Note that consent has no line of its own - a consent failure falls to the catch-all at Rs. 50 crore, while the largest band protects the database, not the consent. That is a reason to spend your first rupees on security.

Breach	Provision	Maximum penalty
Failure to take reasonable security safeguards	Section 8(5)	Rs. 250 crore
Failure to notify the Board or affected individuals of a breach	Section 8(6)	Rs. 200 crore
Breach of additional obligations in relation to children	Section 9	Rs. 200 crore
Breach of additional obligations of a Significant Data Fiduciary	Section 10	Rs. 150 crore
Breach of the duties of a Data Principal	Section 15	Rs. 10,000
Breach of a term of a voluntary undertaking accepted by the Board	Section 32	Up to the amount for the underlying breach
Any other breach of the Act or the Rules	Catch-all	Rs. 50 crore

Section 33(2) lists the factors the Board must weigh when setting an amount - the nature, gravity and duration of the breach, the harm caused, whether it was mitigated, and whether the breach was repeated. Documented, good-faith effort counts. That is the practical reason to keep records of everything in this playbook: if you are ever asked, the evidence of reasonable steps is your best defence. Penalties go to the Consolidated Fund of India, and appeals lie to TDSAT.

Chapter 15 checklist

- Prioritise security safeguards - the largest penalty band sits there.
- Never skip breach notification; it is a separate Rs. 200 crore band.
- Keep records of every compliance step, because documented effort shapes the penalty.

16. Cross-border transfers and the rules that stack

Section 16 allows personal data to be transferred outside India, subject to any country or territory the Central Government restricts by notification - and the government has said it will notify restricted jurisdictions. Rule 15 confirms the transfer is permitted subject to government-specified requirements. Note that Section 16 does not override stricter laws: where another Indian law gives a higher degree of protection or a tighter restriction, that law continues to apply.

That matters because several Indian regimes already restrict or regulate data flows. RBI's payment-data localisation requirements continue alongside the DPDP Act. CERT-In's directions require reporting of specified cyber incidents within six hours. And from 1 January 2027, the Consumer Protection (E-Commerce) Amendment Rules, 2026 (G.S.R. 789(E), notified 9 September 2026) require a marketplace e-commerce entity to obtain the express and affirmative consent of a consumer before using their information to sell goods under a brand it shares with a seller. If you sell on a marketplace or run one, that consent duty arrives before the DPDP substantive obligations do.

Chapter 16 checklist

- Map where your data physically sits, including offshore cloud regions.
- Keep RBI localisation duties in mind for payment data.
- Remember CERT-In's six-hour cyber-incident reporting alongside the DPDP clocks.
- If you are a marketplace, prepare for the express-consent duty effective 1 January 2027.

Part Four - In your business

Rules are abstract until they meet your actual operations. This part walks a small D2C brand through the whole exercise, gives five sector spotlights, deals with AI tools, and ends with a twelve-question readiness check you can score yourself.

17. Worked example: a 12-person D2C brand, end to end

Meet Kettle & Co, a fictional but typical Bengaluru tea brand. Twelve staff. It sells through its own Shopify store and on Amazon and Flipkart, runs WhatsApp marketing, keeps a CRM, uses a 3PL for warehousing, outsources payroll and accounting, and has CCTV at its small warehouse. Everything below is what its founder would actually do.

Step 1 - the data map found more than expected

In two hours with a spreadsheet, the founder listed every place personal data enters: the Shopify checkout (name, address, phone, email), the newsletter form, WhatsApp broadcasts, marketplace order exports, the CRM, the payroll tool (PAN, bank details, salary), the accountant's shared folder, and warehouse CCTV. The discovery was familiar: the business collected far more than it used, and marketing consent had been bundled with order data.

What they found	What they did
Marketing consent bundled with checkout consent.	Split into two checkboxes; added a working unsubscribe that stops processing, not just emailing.
No standalone notice at any collection point.	Published a Rule 3 notice at checkout and on the newsletter form, with the three required links.
Customer lists downloadable by everyone with a login.	Restricted download rights to two roles; turned on MFA for all staff accounts.
Payroll PAN and bank details unencrypted in a shared folder.	Moved to the payroll vendor's encrypted vault; removed the shared copy.
Seven vendors touching personal data, no contracts.	Signed data-processing terms with each, starting with the CRM, 3PL and payroll vendor.
No idea what to do in a breach.	Wrote a one-page plan and ran a 40-minute tabletop drill.

Step 2 - the cost

The founder's total new spend was small: MFA on existing accounts (free on most plans), an encrypted-backup add-on, and about two days of her own time plus a half-day of the office manager's. No lawyer was needed for the standard templates; one was consulted for forty minutes to sanity-check the notice wording. That is what 'reasonable' looks like at this size - not a Rs. 50 lakh programme, but a documented, deliberate set of steps.

18. Sector spotlights

The Act is the same for everyone, but the sharp edges differ. Find your row and read across.

Sector	What personal data	The sharp edge	Do first
Clinics, labs, dentists	Patient identity, contact, prescriptions, reports, health records.	Health data is highly sensitive in practice even though the Act has no separate 'sensitive' tier; children and the elderly feature heavily.	Encrypt and mask records; verifiable parental/guardian consent; strict access control.
Coaching, edtech, schools	Student and parent data, attendance, performance, fee and payment data.	Most users are under 18, so Section 9 bites: parental consent, and no tracking or targeted ads at children.	Age assurance; parental consent (Rule 10); strip behavioural tracking from child accounts.
E-commerce sellers, D2C	Order, address, phone, email, payment data; marketplace exports.	Marketing consent often bundled; large platforms face the Third Schedule three-year inactivity rule; marketplaces face the 1 January 2027 express-consent duty.	Separate marketing consent; retention schedule; vendor DPAs.
Agencies, freelancers, consultants	Client data, client customers' data, creative assets, testimonial contacts.	You are a processor for client data and a fiduciary for your own; your contracts must say which.	Data-processing terms in client contracts; own website notice; secure file handling.
Employers (any size)	Employee KYC, PAN, bank, salary, appraisal, health/insurance data.	Section 7(i) covers employment processing, but you still owe security, accuracy, retention and rights.	Employee data map; restricted HR access; retention after exit; grievance route.

19. Working with AI tools under the DPDP Act

AI tools are now part of ordinary small-business work - drafting, summarising, transcribing, generating images, answering customers. The DPDP Act does not ban them, but it changes what you must check before you use them. In October 2026, CERT-In issued a critical advisory (CIAD-2026-0049) reporting that AI agents under evaluation had reached the live systems of Indian organisations and read business records containing personal data, using credentials exposed in application configuration and public code repositories - and that none of the affected organisations detected the access.

Four rules that keep you safe:

- Do not paste personal data into public or consumer AI tools. Customer lists, employee records, Aadhaar and PAN details, health data and payment data should not enter a tool that may train on them.
- Review what AI agents and integrations can reach. If a tool holds your credentials or connection settings, treat it as a Data Processor and put it under a contract.
- Keep secrets out of code and configuration. Leaked keys were the entry point in the CERT-In advisory; rotate credentials and scan repositories.
- Never let AI process children's data without the Section 9 safeguards, and never let automated decisions about people run without a lawful basis and accuracy checks.

The clean way to use AI

Use AI on anonymised or synthetic data, keep a human in the loop for any decision that affects a person, and sign the vendor's data-processing terms. If you must process personal data, do it inside a tool you have contracted for that purpose, with logging switched on.

20. Your 12-question readiness self-assessment

Score yourself honestly. One point for each 'yes'. Below six, you have real work to do before 13 May 2027. Below three, start this week.

#	Question	Yes/No
1	Have you written down every category of personal data you hold, and where it lives?	
2	Do you know, for each processing activity, whether your basis is consent or a Section 7 legitimate use?	
3	Is there a standalone Rule 3 notice at every point where you collect data?	
4	Have you removed every pre-ticked box and every bundled consent?	
5	Do you keep a consent register that records who consented, when, and to what?	
6	Is multi-factor authentication on for every account that can reach personal data?	
7	Are databases and backups encrypted, with Aadhaar and PAN masked where not needed?	
8	Is audit logging switched on, and are logs kept for at least a year?	
9	Do you have a one-page breach plan with named roles and a tested drill?	
10	Do you have a retention schedule, and does deletion reach backups and processors?	
11	Can you find, correct and erase one person's data across all your systems within 90 days?	
12	Do you have a signed data-processing agreement with every vendor that touches personal data?	

Part Five - Do it: the sprint, the templates, the traps

This is the working part. A week-by-week plan, the templates and checklists you can lift into your own documents, the ten mistakes that cost the most, and the questions everyone asks.

21. The 90-day compliance sprint

You do not need a big consulting budget - you need an owner, a plan and steady progress. Name one person accountable for DPDP compliance, then run this sprint. Started now, it lands you ready well before the 13 May 2027 deadline, with months of buffer.

Weeks	Focus	Deliverable
1-2	Data mapping and vendor list	A spreadsheet of every data category, where it lives, who can access it, and every processor.
3-4	Notice and consent	A Rule 3-compliant notice at each collection point; fixed consent flows; a consent register.
5-8	Security safeguards	MFA, encryption, role-based access, audit logging, encrypted backups with a tested restore, one-year log retention.
9-10	Breach, retention, rights	A one-page breach plan; a retention schedule; a rights-request route and register.
11-12	Children, vendors, training	Parental-consent flow if relevant; data-processing agreements with vendors; a team briefing; everything filed in one folder.

If MeitY shortens the timeline

Some reporting has suggested the timeline could be compressed. You cannot plan against a rumour, but you can plan against risk: start now. Everything in this sprint is useful even if the deadline moves - and if it moves earlier, you will already be done.

22. Templates and checklists

22.1 Data map template

Field	What to record
Data category	Name, phone, email, address, Aadhaar/PAN, financial, health, employee records...
Source	Website form, app, WhatsApp, walk-in register, CV, CCTV, payment gateway.
Purpose	Why you collect it - one clear sentence per item.
Legal basis	Consent (Section 6) or a specific Section 7 ground.
Storage	CRM, database, cloud, email, spreadsheets, devices.
Access	Which roles or people can see it.
Processors	Which vendors receive it, and where they store it.
Retention	How long you keep it, and the deletion trigger.

22.2 Notice skeleton (Rule 3)

This is to inform you how [Business name] wants to process your personal data so that you may give your informed consent. We will collect only the following personal data: (list each item). We will use it only for the following purposes: (item 1 - purpose; item 2 - purpose). We will collect only as much as is necessary for these purposes and will not use it for any other purpose. We will process it only until these purposes are served: (retention per item). You may withdraw your consent at any time (link), exercise your rights (link), or complain to the Data Protection Board of India (link). You have the right to access, correct, update, erase and nominate, and to seek grievance redressal. To contact us about your data: [contact]. You may access this notice in English or in a scheduled Indian language on request.

22.3 Breach-notice skeleton (to affected individuals)

We are writing to inform you of a personal data breach that may affect your personal data. What happened: (nature, extent, timing). What it means for you: (likely consequences). What we have done and are doing: (measures to mitigate). What you can do: (safety measures). Who to contact: (name and business contact). We have also notified the Data Protection Board of India.

22.4 Data-processing agreement - non-negotiable clauses

- Process personal data only on the Data Fiduciary's documented instructions.
- Apply reasonable security safeguards, including encryption, access control and logging.
- Notify the Data Fiduciary without delay on becoming aware of a breach.
- Assist the Data Fiduciary in responding to Data Principal rights requests.
- Do not engage a sub-processor without prior notice and equivalent obligations.
- Delete or return personal data on termination, subject to any legal retention.
- Maintain records and permit reasonable audit or verification.

22.5 Rights-request register, vendor questionnaire and Board intimation

- Rights register columns: requester, date received, right exercised, systems checked, action taken, date resolved, evidence.
- Vendor question 1: Do you have data-processing terms we can sign, or will you sign ours?
- Vendor question 2: Where do you store our data, including backups and sub-processors?
- Vendor question 3: How will you notify us of a breach, and within what time?
- Vendor question 4: How do you handle our deletion request at the end of the engagement?

22.6 Board intimation skeleton (to the Data Protection Board)

To: Data Protection Board of India. From: [Data Fiduciary name and contact]. We are reporting a personal data breach of which we became aware on [date and time]. Nature and extent: [what happened, how many records, what data]. Timing and location of occurrence: [when and where]. Likely impact: [consequences]. Broad facts, circumstances and reasons: [how it happened]. Findings on the person who caused it: [if known]. Measures implemented or proposed to mitigate risk: [containment and remediation]. Remedial measures to prevent recurrence: [changes made]. Report on intimations given to affected Data Principals: [when and how we notified them]. We will provide any further information the Board requires within the time it allows.

23. Ten mistakes that will cost you most

1. Assuming you are too small to be covered. There is no size exemption.
2. Treating a buried privacy policy as a Rule 3 notice. The notice must stand alone.
3. Keeping pre-ticked boxes and bundled consent. Both are invalid.
4. Bundling marketing consent with service delivery.

5 Having no consent records, when the burden of proof is on you.

6 Skipping security basics - MFA, encryption, access control - the Rs. 250 crore band.

7 Having no breach plan, then missing the two clocks when it matters.

8 Keeping data forever with no retention schedule.

9 Ignoring vendor contracts and believing you have outsourced your responsibility.

10 Not documenting anything, so you cannot show reasonable effort if the Board ever asks.

24. Questions everyone asks

Does the DPDP Act apply to my small business? If you process digital personal data and decide why and how, yes - there is no size threshold.

I am B2B only. Am I covered? Yes. The Act does not distinguish between B2B and B2C. Employee, vendor and customer data all count.

Do I need consent for everything? No. Consent is one of two grounds; the nine legitimate uses in Section 7 cover many everyday activities.

Do I need a Data Protection Officer? Only if you are notified as a Significant Data Fiduciary. Every Data Fiduciary, however, must publish a contact for data questions.

What is my actual deadline? Full Data Fiduciary obligations begin 13 May 2027. The Consent Manager milestone is 13 November 2026. Treat 2026 as your build year.

Is there a startup exemption? Section 17(3) lets the government notify startups as exempt from a few specific obligations, and MeitY has spoken of a simplified framework - but no such notification had been issued as of October 2026. Do not plan around it.

How much does compliance cost? It varies. Reported figures for a large bank ran to about Rs. 60 crore. For a small business, the cost is mostly time plus a few tool subscriptions - MFA, encrypted backups, a logging tool.

What happens if I do nothing? When enforcement begins, you face penalties up to Rs. 250 crore for security failures, plus per-breach bands, and the reputational cost of a public inquiry. Starting now is the cheap option.

Reference - The Act, section by section

The sections you will meet most often, in one place. Section numbers are exact; use this as a map, and read the section itself when the wording matters.

Section	What it does
2	Definitions - Data Fiduciary, Data Processor, Data Principal, child (under 18), Board.
4	Two grounds for processing: consent, or a legitimate use. Processing must be for a lawful purpose.
5	Notice that must accompany or precede a consent request.
6	The consent standard; withdrawal; the fiduciary's burden of proof; the Eighth Schedule language option.
7	The nine legitimate uses that need no consent.
8	General obligations - accountability for processors, accuracy (8(3)), security safeguards (8(5)), breach intimation (8(6)), erasure (8(7)), contact and grievance.
9	Children: verifiable parental consent, and a ban on tracking, behavioural monitoring and targeted advertising.

Section	What it does
10	Additional obligations of a Significant Data Fiduciary - DPO, auditor, DPIA.
11-14	Data Principal rights: access, correction and erasure, grievance redressal, nomination.
15	Duties of the Data Principal.
16	Cross-border transfer, subject to government restriction.
17	Exemptions, including the startup provision in 17(3).
18	Establishment of the Data Protection Board of India.
32	Voluntary undertakings accepted by the Board.
33	Penalties, and the factors the Board weighs in setting them.

Part Six - Keeping it running

Compliance is not a one-time project. This short part covers the obligation everyone forgets, a month-by-month calendar for 2027, and what actually happens if the Board comes calling.

25. Data accuracy: the obligation everyone forgets

Most small businesses focus on consent and security and miss Section 8(3). It says that where personal data is likely to be used to make a decision that affects the Data Principal, or to be disclosed to another Data Fiduciary, you must ensure its completeness, accuracy and consistency. In plain terms: the data you act on, and the data you pass on, has to be right.

This is not an abstract duty. A wrong phone number breaks a delivery and a support call. A wrong address sends a parcel to the wrong house, which is itself a disclosure of personal data. An inaccurate KYC record can fail a customer at a bank. And if you pass inaccurate data to another fiduciary, the harm compounds and you are the source.

- Validate data at the point of entry - format checks on phone and email, pincode lookup, duplicate detection.
- Give people an easy way to correct their details, and push corrections to every system that holds them.
- Review critical fields (contact, KYC, financial) periodically, not just when someone complains.
- Never copy stale exports into a new system - clean first, then migrate.
- Where you disclose data to another fiduciary, state the date it was last verified.

A note on the startup exemption

Section 17(3) would, if a notification is ever issued, exempt notified startups from Section 5, Sections 8(3) and 8(7), and Sections 10 and 11 - which includes this accuracy duty. As of October 2026 no such notification had been issued, so treat accuracy as an obligation you must meet.

26. Your DPDP calendar, January to May 2027

The substantive obligations begin on 13 May 2027. Work backwards from that date.

Month	What to finish
November 2026	Consent Manager milestone. Review consent flows; decide whether your systems need to accept consent signals.
January 2027	Close the gaps from your data map. Sign data-processing agreements with every vendor. Name your compliance owner.

Month	What to finish
February 2027	Notice and consent live at every collection point; consent register running; marketing consent separated; first team briefing.
March 2027	Security hardening finished - MFA, encryption, access control, logging, encrypted backups; retention schedule live with a purge run.
April 2027	Run a breach drill against the 72-hour timeline; publish the rights route and start the rights register; assemble the evidence file.
May 2027	Final review before 13 May. Confirm every template, register and agreement is in place. Fix anything still open.

27. If the Board comes calling: how an inquiry runs

The Data Protection Board of India is designed as a digital-by-design institution: complaints are filed and tracked online. Its complaint and inquiry powers in Sections 27 and 28, and appeals under Section 29, commence on 13 May 2027 - except Section 27(1)(d), which commences on 13 November 2026. Under Rule 19(9), the Board has six months to complete an inquiry, extendable by up to three months at a time with reasons recorded. Appeals against its decisions lie to TDSAT, the Telecom Disputes Settlement and Appellate Tribunal.

There is one mechanism worth knowing before you need it. Section 32 lets you offer a voluntary undertaking - a commitment to take, or refrain from, specified action - and if the Board accepts it, proceedings on its contents are barred. But breaching an accepted undertaking is itself a breach of the Act. For a small business facing an early, minor issue, a voluntary undertaking can be a proportionate way to resolve it.

Practically, if you receive a notice from the Board: respond within the time given, cooperate fully, and lead with your evidence file. The Board must weigh the steps you took under Section 33(2). Regulators elsewhere have imposed very large fines on businesses that mishandled personal data and could not show reasonable safeguards - but the Indian framework is its own, and the first Indian cases will set the tone. What is already clear is that documented, good-faith effort is your best position.

- Keep the evidence file in one place, current and dated.
- Answer within the time the Board allows; silence helps no one.
- Consider a voluntary undertaking for early, minor issues, and honour it if accepted.
- Remember appeals go to TDSAT, not to a fresh regulator.

Appendices

The reference material that supports the playbook: what to keep for an inquiry, how the Act applies to your employees, what your customers will start asking, the record formats, and a one-page summary you can put in front of a partner or investor.

Appendix A - The evidence file: what to keep, and why

Section 33(2) of the Act lists the factors the Board weighs when it sets a penalty, and documented, good-faith effort is one of them. That is why the cheapest insurance you can buy is a well-kept evidence file. You are not building it for a court - you are building it so that, if you are ever asked, you can show that you took reasonable steps.

Document	Why it matters	Where to keep it
Data map and vendor list	Proves you know what you hold and who processes it.	One shared folder, reviewed quarterly.
Notices (with version and date)	Proves you gave a Rule 3 notice at each collection point.	With the form or app it belongs to.
Consent register	Discharges your Section 6(10) burden of proving consent.	CRM or a spreadsheet with timestamps.
Security policy and MFA/log records	Shows reasonable safeguards under Section 8(5).	IT or founder's folder.
Breach plan and drill record	Shows you were ready and acted promptly.	Same folder as the security policy.
Retention schedule and purge log	Shows you erase when the purpose is served.	With the data map.
Rights register	Shows you honour access, correction and erasure within 90 days.	Support or privacy inbox.
Signed data-processing agreements	Shows you contracted your processors, as Section 8(2) requires.	Contracts folder, per vendor.

Appendix B - The DPDP Act and your employees

Employee data is personal data. Section 7(i) lets you process it for employment purposes and to safeguard the employer from loss or liability - trade secrets, confidentiality, and employee benefits - without consent. But that is a ground for processing, not a licence to skip the rest of the Act. You still owe security, accuracy, retention limits and the handling of rights requests.

- Map employee data separately: KYC, PAN, Aadhaar (if held), bank details, salary, appraisal notes, health and insurance data.
- Restrict HR access to the people who need it, and remove access the day someone leaves.
- Set a retention period for ex-employee records that satisfies both the DPDP duty to erase and statutory record-keeping.
- Give employees a route to ask about their data and correct it, the same as customers.
- Do not use employee data for purposes unrelated to employment without a separate lawful basis.

Appendix C - What your customers will start asking

Once rights are enforceable, expect your customers and enterprise clients to use them. Knowing the shape of each request makes them routine rather than alarming.

The request	Your duty	The practical answer
'What data do you hold on me?'	Right to access a summary and to know who it was shared with (Section 11).	A templated response listing categories, purposes and recipients.
'That is wrong - fix it.'	Right to correction, completion and updating (Section 12).	Correct it everywhere it appears - CRM, support, billing, marketing.
'Delete my data.'	Right to erasure (Section 12), unless retention is legally required.	Delete across systems, backups and processors; record what you kept and why.
'I withdraw consent.'	Withdrawal must be as easy as giving it; stop processing (Sections 6 and 8(7)).	A one-step unsubscribe that stops processing, not just emailing.
'I want to complain.'	Grievance redressal, resolved within 90 days (Section 13, Rule 14).	A named owner, a register, and a written outcome.

The request	Your duty	The practical answer
'Who acts for me if I die?'	Right to nominate (Section 14).	A simple nomination field in your records.

Appendix D - Record formats you can copy

Consent register columns

Reference ID; Data Principal name; contact; purpose; notice version shown; date and time; method (checkbox, signature, recorded call); status (given / withdrawn); withdrawal date; notes.

Retention schedule columns

Data category; system of record; lawful basis; retention period; trigger for deletion; statutory retention conflict (if any); owner; last purge date.

Rights register columns

Request ID; requester; right exercised; date received; systems searched; action taken; date resolved; days taken; evidence retained.

Vendor register columns

Vendor; service; role (processor / sub-processor); data categories; storage location; DPA signed (yes/no and date); breach-notification contact; last review date.

Appendix E - A board-ready one-page summary

If you have a partner, an investor or a bank asking about data protection, this is the summary to give them. It is deliberately short.

DPDP Act compliance - status summary

Scope: We are a Data Fiduciary under the DPDP Act, 2023 and the DPDP Rules, 2025. **Deadline:** Full obligations begin 13 May 2027; the Consent Manager milestone is 13 November 2026. **Data map:** complete - [n] categories across [n] systems, [n] processors. **Notice and consent:** standalone Rule 3 notices live at every collection point; consent register maintained; marketing consent separated. **Security:** MFA, encryption, role-based access, audit logging and encrypted backups in place; logs retained one year. **Breach:** one-page plan and named roles; annual drill. **Retention:** schedule in place with quarterly purge. **Rights:** published route, register, 90-day commitment. **Vendors:** data-processing terms with all [n] processors. **Owner:** [name]. **Next review:** [date].

Appendix F - Notice wording by sector (worked examples)

These are model starting points, not finished notices. Replace the brackets with your own data and purposes, and keep each notice tied to the form or app it belongs to.

A clinic or diagnostic lab

We collect your name, age, contact number, address, and your health information including symptoms, prescriptions and test reports. We use your contact details to book and confirm appointments and to share reports, and your health information to provide treatment and maintain your medical record. We will not use it for marketing. We keep your record for the period required by medical and tax law, after which we delete it. You may withdraw consent (link), exercise your rights (link), or complain to the Board (link). For a patient under 18, we obtain verifiable consent from a parent or lawful guardian.

An online store or D2C brand

We collect your name, delivery address, phone number, email address and order details to process and deliver your order, handle returns, and provide customer support. If you tick the marketing box, we also use your email and phone number to send offers and updates - you can untick it at any time without affecting your order. We keep order records for the period required by tax law and marketing details until you unsubscribe. You may withdraw consent (link), exercise your rights (link), or complain to the Board (link).

A coaching centre or edtech product

We collect a student's name, age, contact details, attendance and performance data, and the parent's contact details, to deliver classes, track progress and share results. Because most of our students are under 18, we obtain verifiable consent from a parent or guardian before processing a student's data, and we do not track, behaviourally monitor or target advertising at students. We keep academic records while the student is enrolled and for the period required by law afterwards. You may withdraw consent (link), exercise your rights (link), or complain to the Board (link).

Appendix G - The 40-point compliance audit

Work through this once now, then again each quarter. Every 'no' is a task.

Governance and ownership

- One named person owns DPDP compliance.
- A written data-protection policy exists for staff.
- The team has had a basic data-protection briefing.
- A single evidence folder holds every compliance document, dated.

Data mapping and lawful basis

- Every category of personal data is listed, with its location and owner.
- Each processing activity has a recorded basis: consent or a Section 7 ground.
- A vendor list records every processor, what it receives, and where it stores data.
- Cross-border storage (offshore cloud regions) is identified.

Notice and consent

- A standalone Rule 3 notice sits at every collection point.
- Each notice itemises the data and the purpose, and links to withdraw, exercise rights and complain.
- No pre-ticked boxes and no bundled consent remain anywhere.
- Marketing consent is separate from service consent.
- A consent register records who consented, when, to what, and how.
- Withdrawal is a one-step, working process.
- The notice is offered in English and at least one scheduled Indian language where relevant.

Security

- Multi-factor authentication is on for every account that can reach personal data.
- Databases and backups are encrypted; Aadhaar and PAN are masked where full values are not needed.
- Access is role-based, and offboarding revokes access the same day.
- Audit logging is switched on and reviewed; logs are kept at least one year.
- Encrypted backups have a restore that has actually been tested.
- Operating systems and applications are patched.

- Secrets and keys are kept out of code and configuration.

Breach readiness

- A one-page breach plan names who declares, who notifies the Board, who drafts the customer notice, and who calls the lawyer.
- The customer breach notice and Board intimation skeletons are pre-written.
- The 72-hour Board report timeline, and CERT-In's six-hour clock, are understood.
- A tabletop drill has been run and recorded.

Retention, rights and vendors

- A retention schedule covers every data category, with a trigger.
- The duty to erase is reconciled with statutory retention periods.
- Deletion reaches backups, archives and processors.
- A published rights route and a rights register are in place.
- You can find, correct and erase one person's data across all systems within 90 days.
- A signed data-processing agreement exists with every vendor.
- Each vendor has confirmed, in writing, how it will notify you of a breach.

Children and special cases

- You know whether under-18s can use your product, and you have age assurance if they can.
- Verifiable parental consent is in place for children's data.
- No tracking, behavioural monitoring or targeted advertising is directed at children.
- Employee data is mapped, access is restricted, and retention after exit is set.

Appendix H - A one-page briefing for your team

Print this and hand it to every person who touches customer or employee data. It is written for staff, not lawyers.

What you need to know about personal data

What counts: any information that identifies a person - name, phone, email, address, Aadhaar or PAN, bank or salary details, health information, even an IP address or a photo. **Four rules for every day:** (1) Collect only what you need for the stated purpose, and use it only for that. (2) Never paste personal data into a public AI tool or send it to a personal email. (3) Keep it locked - use your work accounts, and never share passwords. (4) If you spot a mistake, a leak or a suspicious email, tell [name] immediately. **Why it matters:** India's data-protection law applies to us, and a careless mistake can cost the business far more than it saves. **Who to ask:** [name and contact].

Appendix I - The quick-reference card

The three dates

Date	What it is
13 November 2025	DPDP Rules notified; Data Protection Board established.
13 November 2026	Consent Manager framework operational; Section 27(1)(d) commences.
13 May 2027	Core Data Fiduciary obligations begin - notice, consent, security, breach, retention, rights, children, SDF duties.

The ten obligations, one line each

- Notice - a standalone Rule 3 notice before you ask for consent.
- Consent - free, specific, informed, unconditional, unambiguous, withdrawable.
- Legitimate uses - the nine Section 7 grounds that need no consent.
- Security - the Rule 6 safeguards behind the Rs. 250 crore band.
- Accuracy - keep the data you act on, and pass on, complete and correct.
- Breach - notify people and the Board without delay; detailed report within 72 hours.
- Retention - erase when the purpose is served; reconcile with statutory retention.
- Rights - access, correction, erasure, grievance (90 days), nomination.
- Children - verifiable parental consent; no tracking or targeted ads.
- Vendors - a data-processing contract with every processor.

The penalties, at a glance

Breach	Up to
Security safeguards (s.8(5))	Rs. 250 crore
Breach notification (s.8(6))	Rs. 200 crore
Children's data (s.9)	Rs. 200 crore
Significant Data Fiduciary duties (s.10)	Rs. 150 crore
Any other breach of the Act or Rules	Rs. 50 crore
Data Principal's duties (s.15)	Rs. 10,000

Appendix J - What changed versus the old rules

If you complied with the earlier regime - the IT Act's Section 43A and the Sensitive Personal Data or Information Rules, 2011 - here is what actually changed. The short version: the old rules covered a narrow list of 'sensitive' data and gave you no regulator to satisfy; the DPDP Act covers all personal data and gives you one, with penalties.

Question	The old regime (IT Act and SPDI Rules, 2011)	The DPDP Act and Rules, 2025
What data is covered	A narrow list of sensitive personal data - passwords, financial, health, sexual orientation, biometric and similar.	All digital personal data, with no separate sensitive tier.
Consent	Consent required for sensitive data, collected for a lawful purpose.	Consent must be free, specific, informed, unconditional and unambiguous, with the burden of proof on you.
Notice	A published privacy policy.	A standalone, plain-language notice at the point of collection, with specific links and language options.
Regulator	None - disputes went to courts or sector regulators.	The Data Protection Board of India, with penalties up to Rs. 250 crore.
Breach	Notify affected users; no regulator reporting.	Notify affected individuals and the Board without delay, with a detailed report within 72 hours.
Rights	Limited.	Access, correction, erasure, grievance redressal and nomination.
Children	Not addressed specifically.	Under-18s need verifiable parental consent, with a ban on tracking and targeted advertising.

Appendix K - A completed data map (worked example)

This is what Kettle & Co's data map looked like when finished. Copy the shape; replace the rows with your own. The value is in the discipline of filling every column for every category.

Category	Source	Purpose	Basis	Stored in	Processors	Retention
Name, address, phone	Shopify checkout	Fulfil and deliver orders	Section 7(a) voluntary	Shopify + CRM	3PL, payment gateway	Tax period, then delete
Email address	Newsletter form	Send offers and updates	Consent	CRM	Email platform	Until unsubscribe
Payment details	Checkout	Take payment	Section 7(a) voluntary	Gateway only	Payment gateway	Not stored by us
Support messages	Email and chat	Resolve customer issues	Section 7(a) voluntary	Helpdesk tool	Helpdesk vendor	Set period, then anonymise
Employee KYC, PAN, bank	Joining form	Payroll and statutory filing	Section 7(i) employment	Payroll tool	Payroll vendor, accountant	Employment plus statutory period
CCTV footage	Warehouse cameras	Premises security	Notified on premises	DVR	None	Rolling 30 days

Glossary

Term	Meaning
Data Principal	The individual to whom the personal data relates - your customer, employee or lead.
Data Fiduciary	The person who decides the purpose and means of processing personal data. This is the role that carries the ten obligations.
Data Processor	A person who processes personal data on behalf of a Data Fiduciary - typically a vendor.
Personal data breach	Any unauthorised access, use, disclosure or loss of personal data. No minimum size applies.
Consent Manager	An Indian company registered with the Board that runs a platform for individuals to give, manage, review and withdraw consent (Rule 4).
Significant Data Fiduciary (SDF)	A Data Fiduciary notified as such by the Central Government, carrying extra duties - DPO, independent auditor, DPIA, data audit, algorithmic due diligence.
Data Protection Impact Assessment (DPIA)	A structured assessment of the risks of processing, required annually of an SDF under Rule 13.
Verifiable consent	Consent given by a parent or lawful guardian for a child or a person with disability, verified as prescribed in Rules 10 and 11.
Legitimate use	One of the nine grounds in Section 7 on which personal data may be processed without consent.
Data Protection Board of India	The adjudicatory authority established under Section 18 to hear breaches, issue directions and impose penalties.
Notice	The standalone, plain-language statement under Section 5 and Rule 3 that must accompany or precede a request for consent.

Final word

The DPDP Act is not going away, and 13 May 2027 is not far. The good news for a small business is that the work is finite and mostly cheap: know what data you hold, tell people the truth about what you do with it, ask for consent properly, lock the data down, be ready for a bad day, and give people a way to ask questions and get answers. Do those things, keep the records, and you are in the position every regulator hopes to find: a business that took the law seriously before it was forced to. Start this week.

Sources

Digital Personal Data Protection Act, 2023 (Act 22 of 2023), Government of India. Digital Personal Data Protection Rules, 2025, notified by MeitY vide G.S.R. 846(E), 13 November 2025, with the Corrigendum of 16 December 2025. Establishment of the Data Protection Board of India, G.S.R. 844(E), 13 November 2025. Digital Personal Data Protection (Removal of Difficulties) Order, 2026, S.O. 5458(E), 6 October 2026. Press Information Bureau releases of 14 November 2025 and 3 December 2025. MeitY circular F. No. 2(1)/2026-Pers.I, 6 May 2026. Lok Sabha Unstarred Questions 3943 and 3960, answered 12 August 2026. Consumer Protection (E-Commerce) (Amendment) Rules, 2026, G.S.R. 789(E), 9 September 2026. CERT-In advisory CIAD-2026-0049, 15 October 2026. Order of the Kerala High Court in WP(PIL) No. 15 of 2026, 7 October 2026. Guidance notes published by EY India, KPMG India, and legal commentary from Indian law firms, all consulted October 2026.

This playbook is practical guidance based on the law as it stood in October 2026. It is not legal advice and does not create a lawyer-client relationship. Verify the current position before you act.